Parte 1: Organigrama del SOC de Ferretería El Martillo

Contexto del escenario

Ferretería El Martillo creció: ahora tiene 30 empleados, 3 sucursales en Lima y un servidor en la nube. La gerencia contrató a un proveedor de servicios de seguridad gestionados (MSSP) que les provee un SOC tercerizado de ~50 analistas rotando en turnos de 8h.

Parte 1: Organigrama del SOC de Ferretería El Martillo

Nivel L1 — Triage Analyst

- **Cantidad de personas en el turno:** 6 analistas L1 por turno (Al ser un MSSP de ~50 personas que opera 24/7/365 en 3 turnos rotativos, se requieren aproximadamente 6 analistas concurrentes en línea para procesar el gran volumen de alertas de Ferretería El Martillo y los demás clientes del pool).
- **Herramientas que usa:** SIEM (Microsoft Sentinel), ticketing (Jira Service Desk).
- **Tipo de alertas que maneja:** Alertas estandarizadas de alto volumen, tales como intentos de fuerza bruta, bloqueos automáticos de malware por antivirus/EDR, o firmas conocidas de escaneadores web (*User Agent Fuzzer*).
- **Tiempo máximo antes de escalar:** 20 minutos.
- **Autorización máxima sin escalamiento:** Clasificación y descarte de falsos positivos conocidos (FPR) que estén explícitamente documentados en las playbooks operativas.

Nivel L2 — Incident Analyst

- **Cantidad de personas en el turno:** 2 analistas L2 por turno (Proporción técnica recomendada para absorber la carga analítica profunda de los casos escalados por el L1).
- **Herramientas adicionales vs. L1:** Consolas completas de EDR/XDR (CrowdStrike), sandboxes para análisis dinámico (Any.Run) y frameworks de recolección forense (FTK Imager, Volatility).
- **Tipo de casos que recibe:** Alertas complejas que superan los flujos estándar de las playbooks, sospechas de persistencia en sistemas operativos, movimientos laterales de red o anomalías críticas en el servidor en la nube de la ferretería.
- **Qué hace que L1 no puede hacer:** Aislamiento activo e investigación manual de hosts comprometidos, reconstrucción de la línea de tiempo de un ataque, ingeniería inversa básica de scripts maliciosos y despliegue de políticas restrictivas de contención perimetral.

Nivel L3 — Senior Analyst / Threat Hunter

- **Cantidad de personas en el equipo:** 1 analista L3 por turno (Especialista senior enfocado en la resolución de alta complejidad técnica).
- **Responsabilidades que no tienen L1/L2:** Ejecución de campañas proactivas de *Threat Hunting*, análisis avanzado de binarios (malware de día cero), desarrollo de integraciones automatizadas complejas (SOAR) y tuning de reglas de detección fina para evitar la fatiga de alertas del nivel L1.

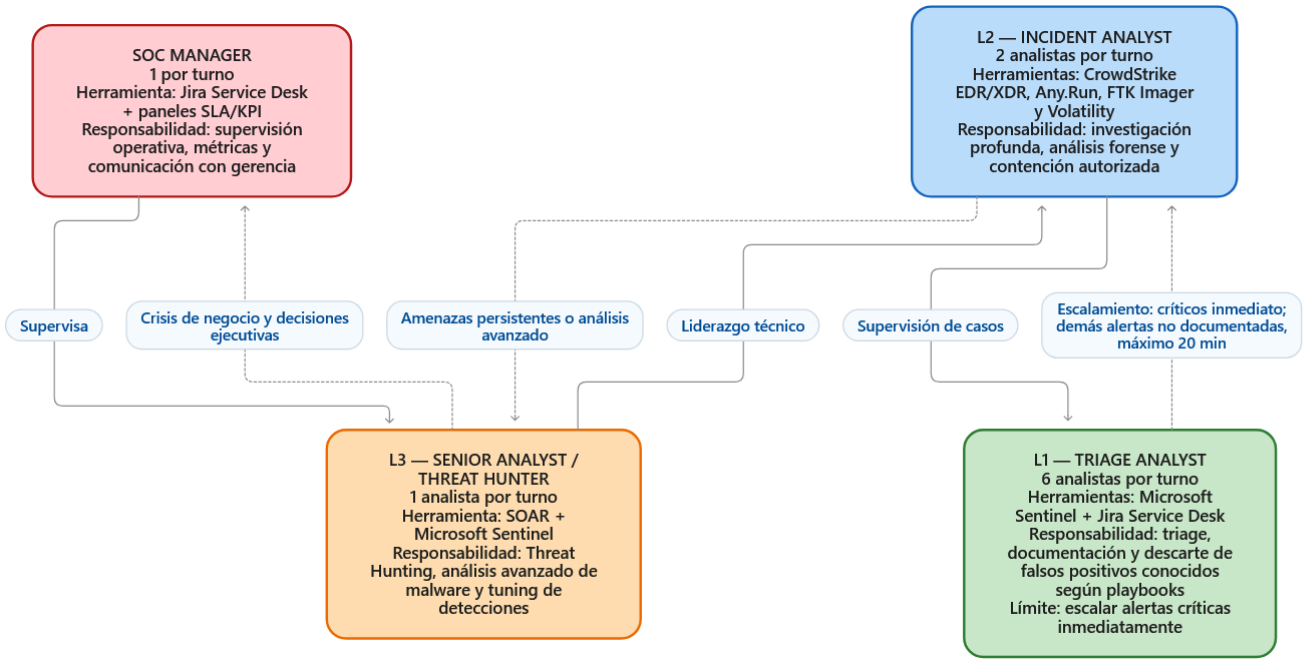
SOC Manager

- **Cantidad de personas:** 1 Manager por turno.

- **Responsabilidad:** Supervisión operativa de la cola de incidentes y aseguramiento de los Acuerdos de Nivel de Servicio (SLAs), interlocución de crisis directa con la gerencia de Ferretería El Martillo y consolidación de métricas analíticas (no realiza investigación técnica directa).

1.2 Integrar el organigrama

Representación Gráfica (Sintaxis nativa en Mermaid)



Parte 2: Flujograma de Escalamiento — 3 Escenarios

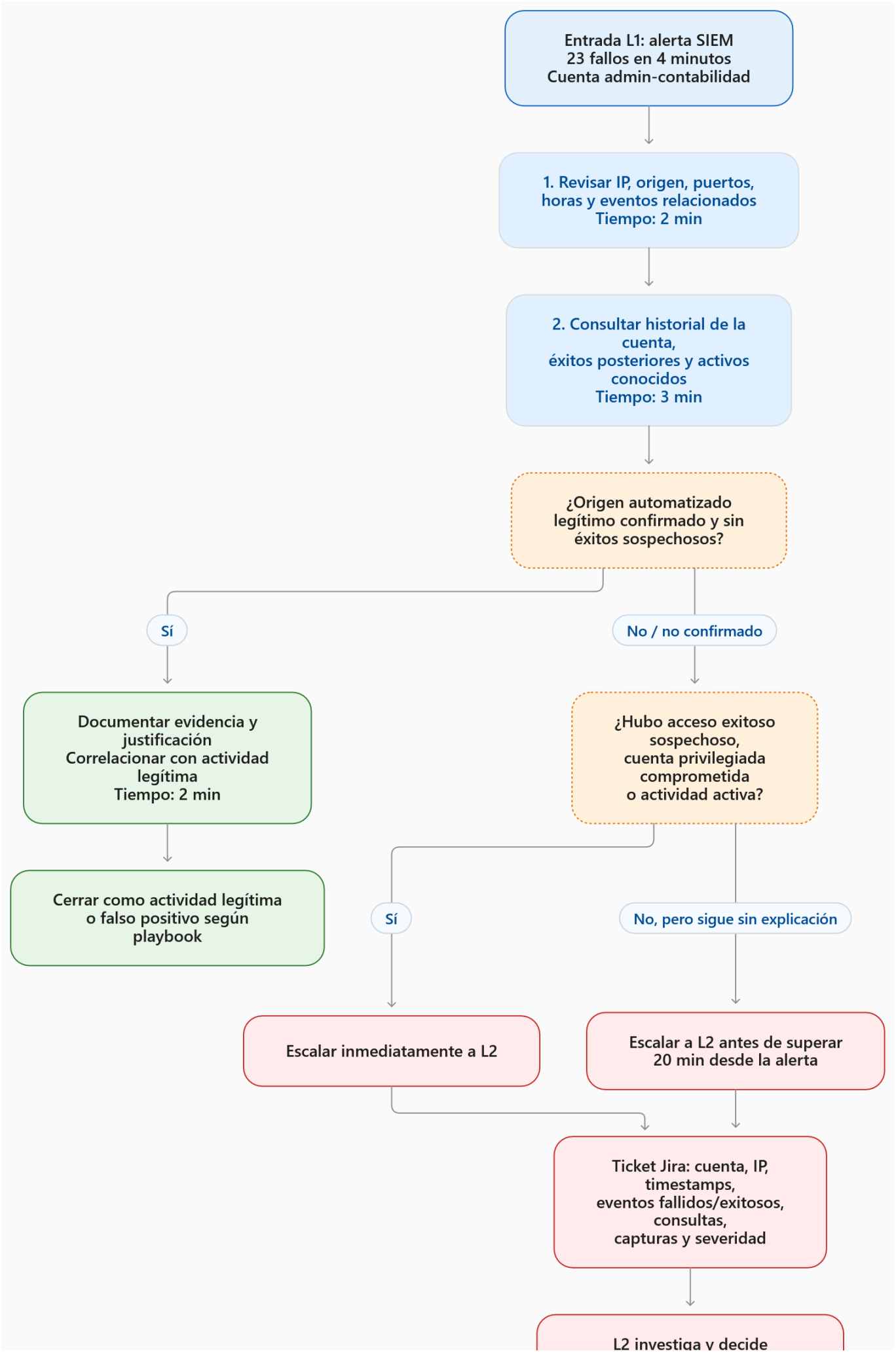
2.1 Desarrollo Analítico de los Procedimientos Operativos (Playbooks)

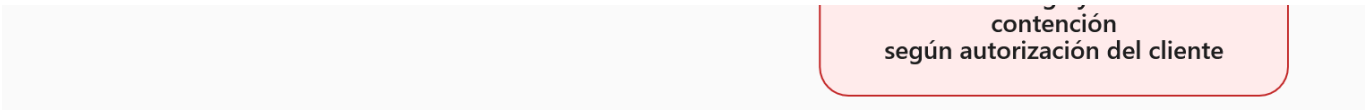
A continuación, se detallan los flujos de decisión y de operaciones que ejecuta el equipo del SOC ante las alertas de la infraestructura de **Ferretería El Martillo**:

Escenario A: Ráfaga de logins fallidos (Ataque de Fuerza Bruta / Credential Stuffing)

Alerta: a las 2:47 AM, 23 intentos fallidos en 4 minutos para admin-contabilidad, desde una IP no reconocida.

La pista importante es verificar si los intentos proceden de una aplicación, tarea programada, VPN o sistema automatizado legítimo; también hay que comprobar si hubo un inicio de sesión exitoso después de los fallos.


Entrada L1: alerta SIEM
23 fallos en 4 minutos
Cuenta admin-contabilidad
1. Revisar IP, origen, puertos, horas y eventos relacionados
Tiempo: 2 min
2. Consultar historial de la cuenta, éxitos posteriores y activos conocidos
Tiempo: 3 min
¿Origen automatizado legítimo confirmado y sin éxitos sospechosos?
Sí
No / no confirmado
Documentar evidencia y justificación
Correlacionar con actividad legítima
Tiempo: 2 min
Cerrar como actividad legítima o falso positivo según playbook
¿Hubo acceso exitoso sospechoso, cuenta privilegiada comprometida o actividad activa?
Sí
No, pero sigue sin explicación
Escalar inmediatamente a L2
Escalar a L2 antes de superar 20 min desde la alerta
Ticket Jira: cuenta, IP, timestamps, eventos fallidos/exitosos, consultas, capturas y severidad
L2 investiga y decide

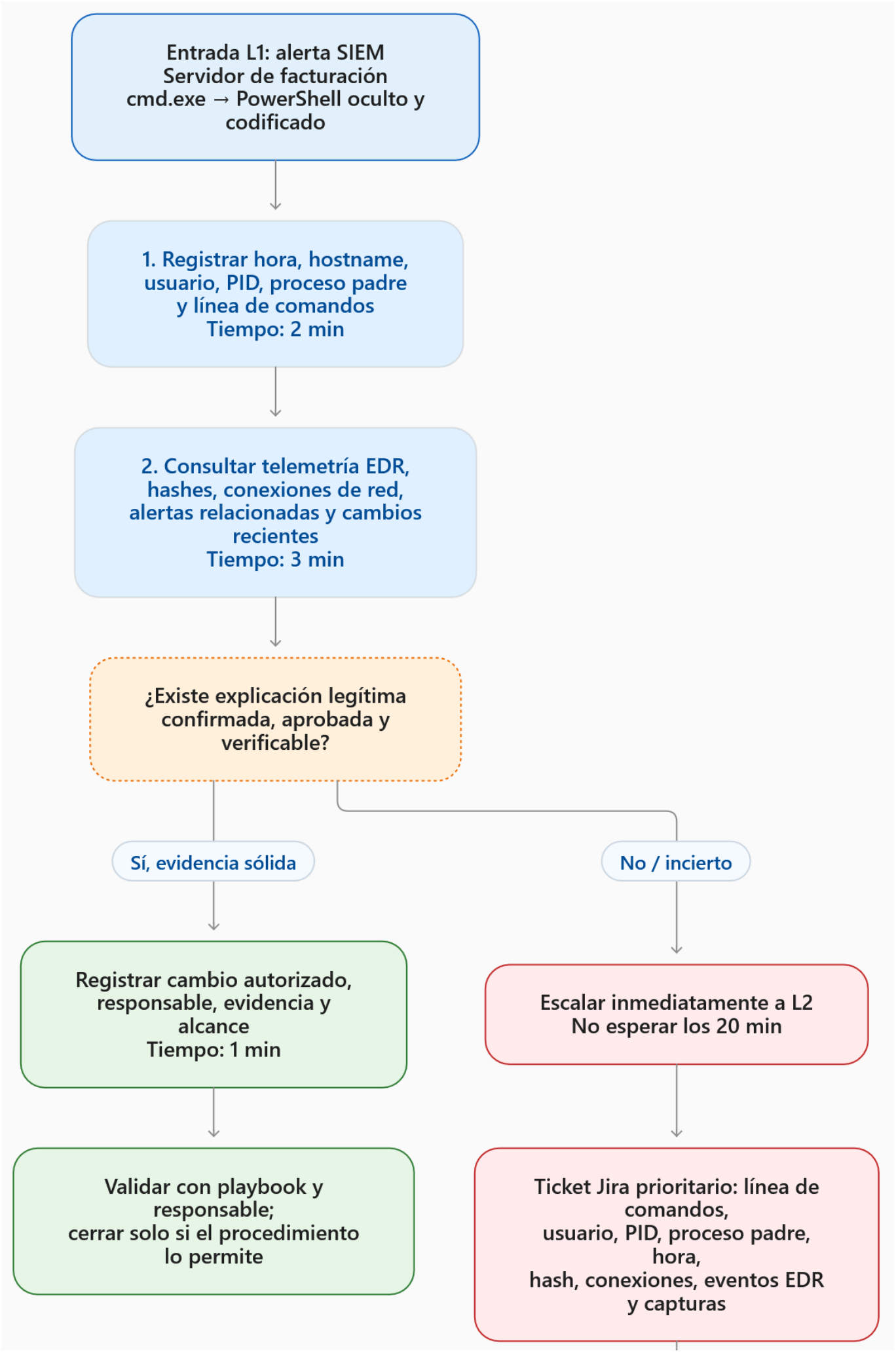


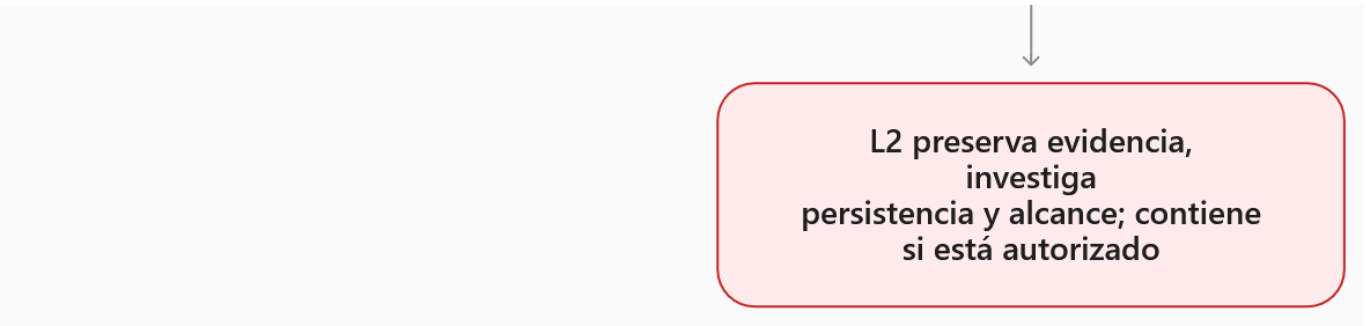
- Tiempo estimado de L1 si no escala: 7 minutos. Si necesita escalar, debe preparar el ticket en paralelo con las comprobaciones restantes, sin retrasar una alerta crítica.

Escenario B: Proceso sospechoso en servidor

Alerta: a las 11:15 AM, el servidor de facturación ejecuta cmd.exe que inicia PowerShell oculto con un comando codificado. Por su contexto y ofuscación, debe tratarse como posible incidente de alta prioridad y escalarse a L2 rápidamente.

Durante los primeros cinco minutos, L1 recopila evidencia sin ejecutar el comando ni intentar decodificarlo en el servidor productivo.


Entrada L1: alerta SIEM
Servidor de facturación
cmd.exe → PowerShell oculto y codificado
1. Registrar hora, hostname, usuario, PID, proceso padre y línea de comandos
Tiempo: 2 min
2. Consultar telemetría EDR, hashes, conexiones de red, alertas relacionadas y cambios recientes
Tiempo: 3 min
¿Existe explicación legítima confirmada, aprobada y verificable?
Sí, evidencia sólida
No / incierto
Registrar cambio autorizado, responsable, evidencia y alcance
Tiempo: 1 min
Validar con playbook y responsable;
cerrar solo si el procedimiento lo permite
Escalar inmediatamente a L2
No esperar los 20 min
Ticket Jira prioritario: línea de comandos,
usuario, PID, proceso padre, hora,
hash, conexiones, eventos EDR y capturas

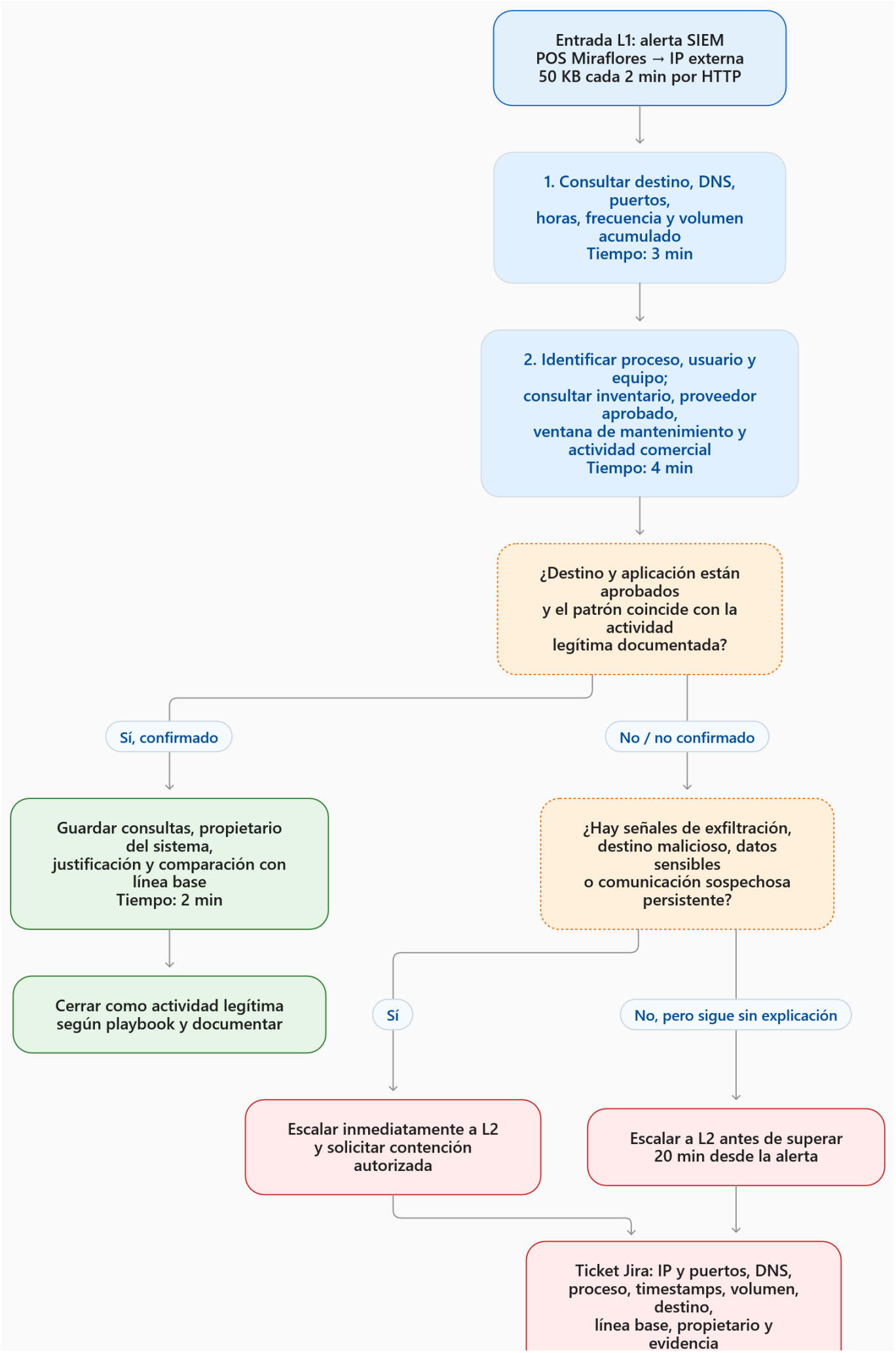


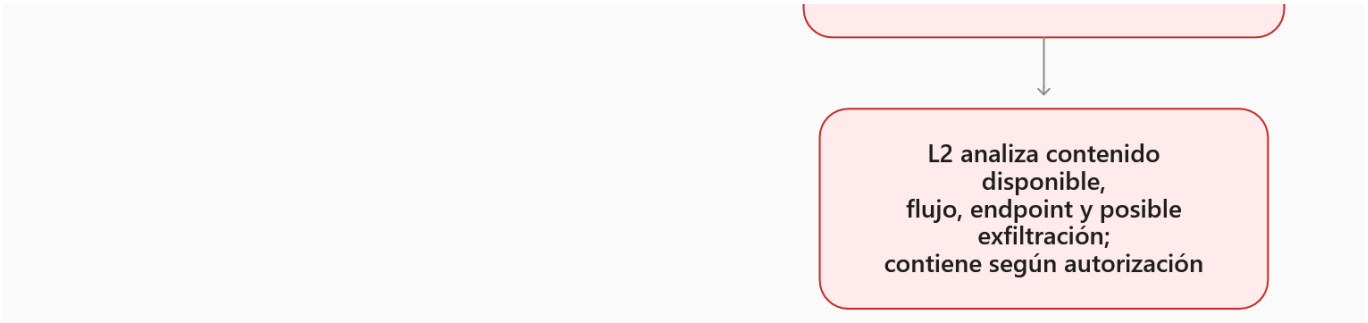
- Tiempo estimado de L1 antes de escalar: 5 minutos de recopilación inicial, con escalamiento inmediato al reconocer el comportamiento sospechoso. La verificación de una explicación legítima no debe retrasar la notificación a L2. Si la evidencia apunta a ejecución maliciosa, L1 no debe cerrar el caso ni borrar archivos.

Escenario C — Tráfico outbound inusual

Alerta: desde las 3:00 PM, el punto de venta de Miraflores envía tráfico HTTP a una IP no reconocida, geolocalizada en Rusia, en ráfagas de 50 KB cada dos minutos.

La geolocalización por sí sola no demuestra que exista un ataque. L1 debe comprobar si el destino pertenece a un proveedor aprobado, qué aplicación genera el tráfico y si el volumen o el horario son normales para ese punto de venta.

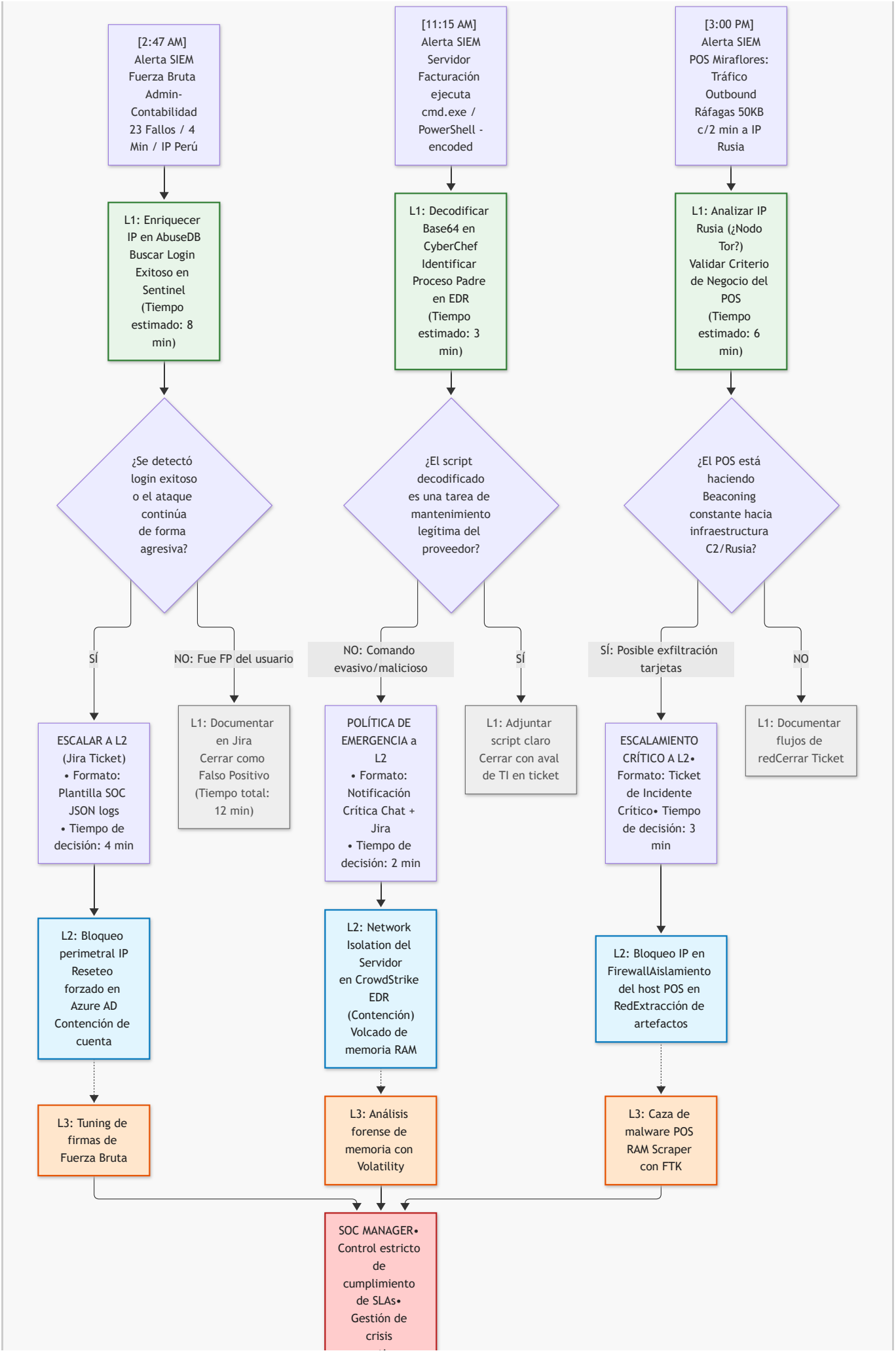

Entrada L1: alerta SIEM
POS Miraflores → IP externa
50 KB cada 2 min por HTTP
1. Consultar destino, DNS, puertos,
horas, frecuencia y volumen acumulado
Tiempo: 3 min
2. Identificar proceso, usuario y equipo;
consultar inventario, proveedor aprobado,
ventana de mantenimiento y actividad comercial
Tiempo: 4 min
¿Destino y aplicación están aprobados
y el patrón coincide con la actividad
legítima documentada?
Sí, confirmado
No / no confirmado
Guardar consultas, propietario del sistema,
justificación y comparación con línea base
Tiempo: 2 min
Cerrar como actividad legítima según playbook y documentar
¿Hay señales de exfiltración, destino malicioso, datos sensibles
o comunicación sospechosa persistente?
Sí
No, pero sigue sin explicación
Escalar inmediatamente a L2 y solicitar contención autorizada
Escalar a L2 antes de superar 20 min desde la alerta
Ticket Jira: IP y puertos, DNS, proceso, timestamps, volumen, destino,
línea base, propietario y evidencia

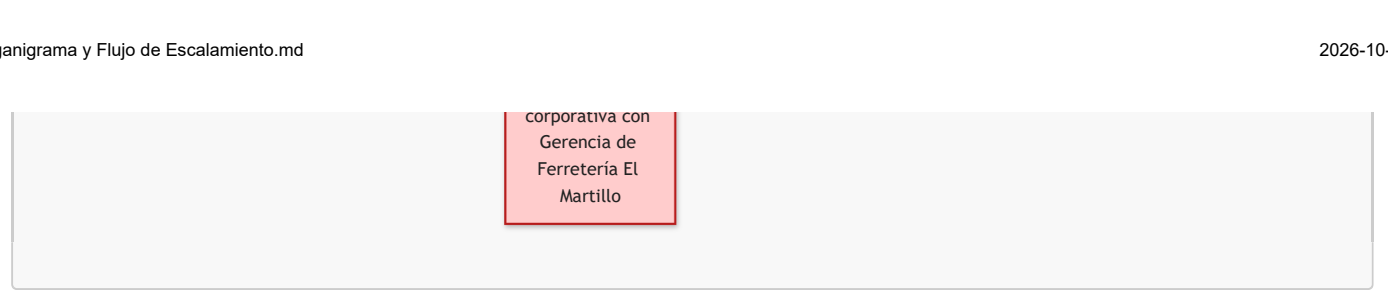


- Tiempo estimado de L1 si no escala: 9 minutos. Si el destino no está aprobado o no se puede explicar el patrón, L1 escala antes de alcanzar el límite operativo. Si aparecen indicios de exfiltración activa o compromiso, escala inmediatamente.

2.2 Flujograma Integrado de Decisiones y Escalamiento (Mermaid)

Este flujograma representa visualmente la lógica, los tiempos de procesamiento en primer nivel y la transición de la información hacia los analistas avanzados (L2 y L3) según el diseño operativo de tu SOC:


[2:47 AM] Alerta SIEM Fuerza Bruta Admin-Contabilidad 23 Fallos / 4 Min / IP Perú
L1: Enriquecer IP en AbuseDB Buscar Login Exitoso en Sentinel (Tiempo estimado: 8 min)
¿Se detectó login exitoso o el ataque continúa de forma agresiva?
SÍ
NO: Fue FP del usuario
ESCALAR A L2 (Jira Ticket) • Formato: Plantilla SOC JSON logs • Tiempo de decisión: 4 min
L1: Documentar en Jira Cerrar como Falso Positivo (Tiempo total: 12 min)
L2: Bloqueo perimetral IP Reseteo forzado en Azure AD Contención de cuenta
L3: Tuning de firmas de Fuerza Bruta
[11:15 AM] Alerta SIEM Servidor Facturación ejecuta cmd.exe / PowerShell -encoded
L1: Decodificar Base64 en CyberChef Identificar Proceso Padre en EDR (Tiempo estimado: 3 min)
¿El script decodificado es una tarea de mantenimiento legítima del proveedor?
NO: Comando evasivo/malicioso
SÍ
POLÍTICA DE EMERGENCIA a L2 • Formato: Notificación Crítica Chat + Jira • Tiempo de decisión: 2 min
L1: Adjuntar script claro Cerrar con aval de TI en ticket
L2: Network Isolation del Servidor en CrowdStrike EDR (Contención) Volcado de memoria RAM
L3: Análisis forense de memoria con Volatility
[3:00 PM] Alerta SIEM POS Miraflores: Tráfico Outbound Ráfagas 50KB c/2 min a IP Rusia
L1: Analizar IP Rusia (¿Nodo Tor?) Validar Criterio de Negocio del POS (Tiempo estimado: 6 min)
¿El POS está haciendo Beaconing constante hacia infraestructura C2/Rusia?
SÍ: Posible exfiltración tarjetas
NO
ESCALAMIENTO CRÍTICO A L2• Formato: Ticket de Incidente Crítico• Tiempo de decisión: 3 min
L1: Documentar flujos de redCerrar Ticket
L2: Bloqueo IP en FirewallAislamiento del host POS en RedExtracción de artefactos
L3: Caza de malware POS RAM Scraper con FTK
SOC MANAGER• Control estricto de cumplimiento de SLAs• Gestión de crisis


corporativa con
Gerencia de
Ferretería El
Martillo